

100 Days of Azure DevOps

Day 83 Handout — A pinch helps; a handful ruins the stew and the security review

9 - Advanced & Enterprise · Personal lab only · Educational content · Not a sales pitch

Architecture A — who runs inside your job

Source	Trust default	Check before install
Built-in tasks	Prefer for every 100-day lab	script, DotNetCoreCLI, PublishBuildArtifacts, Docker
Microsoft-published extension	OK if the task is not already built-in	Publisher = Microsoft, last update, scopes
Known OSS publisher	Maybe — treat as supply chain	Repo, last release, permissions on install
Unknown publisher	No for labs	Wide org scopes + years of silence
Custom private extension	Out of scope for this series	Do not sideload a .vsix you cannot explain

Architecture B — install one or install zero

Question	Install	Write 'zero' when
Is there a built-in task?	Do not install	Always — built-in wins for labs
Publisher + update date defensible?	One extension, note the scopes	Last update years ago or no public repo
Scopes on install	Least privilege; project not org if possible	Extension wants all pipelines + all repos
Feels 'enterprise' to add five tools	Still one or zero	Spice dump on a hello pipeline
Work Marketplace already full	Do not screenshot it	Personal org only

Architecture C — pitfalls the security review can taste

Pitfall	What you see	Fix
Abandoned spice	Task last updated 2018, still in YAML	Remove the task; replace with script/built-in
Tenant guest	Extension can read every pipeline	Uninstall; document why zero
Task name folklore	Nobody knows who published 'SuperScan'	Publisher is part of the bill of materials
Install to feel busy	Five extensions, same hello.yml	Zero + a written reason still finishes the lab
Work org extensions list	You browse the employer Marketplace	https://marketplace.visualstudio.com in a personal tenant

One-liner to remember

Marketplace extensions are spices — a pinch helps; a handful ruins the stew and the security review.

Step-by-step lab (personal Azure / Azure DevOps only)

Personal Azure DevOps org. Prefer built-in tasks. Zero installs with a written reason counts as done.

- 1 Org settings → Extensions (or Marketplace from the personal org). List what is already installed. Screenshot nothing from a work org.
- 2 Browse Marketplace for one task you actually need (or confirm you need none). Record publisher, last update, and requested scopes.
- 3 If publisher/scopes/update are defensible, install that one extension in the personal org. Otherwise install zero.

- 4 Write docs/marketplace-day83.md: the one extension and why, or 'zero — built-in tasks cover the lab' plus the scopes you refused.
- 5 Open a pipeline YAML and confirm it does not reference a mystery task name you cannot map to a publisher.
- 6 Do not sprinkle Replace Tokens / Slack / extra scanners onto a hello pipeline just to look enterprise.

Lab rule — built-in first; third-party is a supply-chain note

```
# Prefer Microsoft-maintained / built-in tasks in YAML, for example:
steps:
- task: UseDotNet@2
  inputs:
    packageType: sdk
    version: '8.0.x'
- script: dotnet test --configuration Release
  displayName: Test (built-in script)
# Third-party: document publisher, permissions, last update – or install zero
```

Done checklist

- Either one defensible install or a written zero
- Publisher, last update, and scopes recorded
- docs/marketplace-day83.md exists
- No work-org Marketplace screenshot
- Posted the LinkedIn document

Tomorrow — Day 84

Jenkins to Azure Pipelines — migrate guarantees, not the blue ball